Chapter 06: Critical Evaluation, Reflection & Future Roadmap

Self-Reflection, ASP.NET Core & API Testing Bottlenecks, BCrypt Hashing, 2FA & Phase 2 Roadmaps

Author: *Pasindu Nirmal Iddamalgoda (Student ID: E269559) • Lead Developer*

6.1 Critical Evaluation of the Developed System

Chapter 06 delivers a rigorous, self-critical appraisal of the Dutch Point Negombo hotel management system. Academic standards require identifying both technical successes and real-world operational bottlenecks encountered during full-stack development.

CRITICAL HIGHLIGHT: Key Interim Triumphs vs Original Baseline

- **Concurrency Integrity:** Successfully trapped double-booking race conditions using Allen's Interval Algebra at the database query tier.
- **Multi-Tier Decoupling:** Proved the viability of a modern decoupled architecture (React 19 + ASP.NET Core C# + PostgreSQL).
- **Financial Precision:** Standardized all room rates and billing in Sri Lankan Rupees (LKR) with decimal(18,2) precision.

6.2 Technical Reflection: ASP.NET Core & API Testing Challenges

6.2.1 ASP.NET Core Learning Difficulties

- **Asynchronous Pipeline (async/await):** Overcame early Kestrel thread starvation caused by blocking .Result calls by migrating completely to non-blocking streaming (.ToListAsync(), .CountAsync()).
- **Circular Entity References:** Resolved JSON serializer crashes caused by bidirectional navigation properties between Customer and Booking by engineering flat Data Transfer Objects (DTOs).
- **Dependency Injection Scoping:** Addressed DbContext concurrency exceptions by properly configuring Scoped service lifetimes in Program.cs.
- **CORS Middleware Bottleneck:** Resolved browser cross-origin blocks between Vite (port 5173) and ASP.NET Core (port 5000) using app.UseCors('AllowAll').

6.2.2 API Testing & Integration Bottlenecks

- **DateTime Timezone Shift:** Fixed an issue where Sri Lanka's UTC+5:30 offset shifted dates backward by 1 day by enforcing UTC midnight (DateTime.UtcNow.Date) normalization.
- **Semantic HTTP Status Mapping:** Refactored generic 200 OK responses to return strict REST codes (HTTP 409 Conflict for double bookings, HTTP 400 for capacity limits).
- **Concurrency Stress Testing:** Used Postman runner to simulate rapid concurrent booking submissions, validating database-level transactional locking.

Table 6.1: Technical Bottlenecks and Applied Solutions

Challenge Area	Observed Bottleneck	Applied Solution
Async Deadlocks	Sluggish response under load	Refactored to async/await streaming
Circular JSON Loops	500 Internal Error on /api/bookings	Decoupled via flat DTO projection models
DateTime Drift	Bookings saved on wrong calendar day	Normalized to UTC DateOnly at API entry
CORS Block	React requests blocked by browser	Registered AddCors middleware in Program.cs

Double Booking	In-memory race conditions	Database interval overlap query returning HTTP 409

6.3 Future System Enhancements (Phase 2 Production Roadmap)

Commercial production hardening requires upgrading the current working prototype with enterprise security and administrative tooling:

1. Production Password Hashing & JWT Security Architecture

Demonstration credentials will be replaced with salted **BCrypt.Net-Next** (work factor 12) or Argon2id hashing, paired with signed JWT authentication tokens stored in HttpOnly, SameSite=Strict cookies to eliminate XSS risks.

```
// BCrypt Password Hashing in AuthController.cs
newUser.PasswordHash = BCrypt.HashPassword(request.Password, workFactor: 12);

// Login Verification against stored hash
bool isValid = BCrypt.Verify(request.Password, user.PasswordHash);
if (!isValid) return Unauthorized(new { message = "Invalid credentials." });
```

Proposed BCrypt Salted Password Hashing Integration

2. Two-Factor Authentication (2FA / Multi-Factor Authentication)

• **TOTP (RFC 6238):** Administrators must verify a 6-digit ephemeral token via Google/Microsoft Authenticator before accessing inventory and financial controls.
• **SMS OTP Fallback:** High-value guest bookings in Sri Lankan Rupees (LKR) will trigger an automated SMS OTP via Twilio to verified mobile numbers (+94).

3. Advanced Executive Admin Dashboard & Analytics Portal

• **Visual Telemetry (Chart.js / Recharts):** Interactive charts tracking Monthly Revenue Yield in LKR, ADR, and RevPAR.
• **Interactive Room Schedule Gantt Timeline:** Visual 30-day horizontal grid allowing front-desk staff to drag-and-drop suite allocations and monitor housekeeping turnovers.
• **Automated PDF Folio Invoicing:** Server-side PDF invoice generation with automated tax breakdowns (VAT / Tourism Levy).

4. Direct Payment Gateway Integration (PayHere / Stripe)

Real-time tokenized card processing in LKR with a 15-minute temporary reservation hold, transitioning to Confirmed only upon receipt of a signed webhook payment confirmation.

6.4 Viva Voce Defense Script (Reflections & Future Plans)

CRITICAL HIGHLIGHT: 30-Second Viva Answer for Chapter 6

"Sir/Madam, our biggest technical challenges were adapting to ASP.NET Core's asynchronous threading model, resolving circular JSON serialization in EF Core, and eliminating timezone date shifts between React and C#.
For our Phase 2 production roadmap, we have designed three essential upgrades: first, implementing BCrypt work-factor-12 password hashing with JWT token rotation; second, enforcing Two-Factor Authentication (TOTP via Google Authenticator) for administrative accounts; and third, expanding the admin module into an executive visual dashboard with interactive Gantt timeline room scheduling and automated LKR payment gateway integration."